

RETEST ETHICAL HACKING

Proyecto: DT.Claro.Miniprogram.TuLlave_Mass | Fecha: 19/05/2026

Target API: <https://superapp-api-test.miniprogramas.claro.com.co> | Total hallazgos: 6
Crítica: 1 | Alta: 0 | Media: 4 | Baja: 1
Priorización: 6 hallazgos — 1 críticos
- Priorizar remediación de hallazgos CRITICAL (secretos, inyección, auth rota).
- 3 check(s) externo(s) omitido(s) (binario ausente o requisito no cumplido); ver tabla en el informe.
Extensiones analizadas: .acss, .axml, .js, .json

#	Vulnerabilidad	Riesgo	CVSS	Estado	Endpoint
1	Hardcoded Credentials	CRITICAL	9.0	Persistente	https://superapp-api-test.miniprogramas.claro.com.co
2	Insecure HTTP Endpoint	MEDIUM	6.0	Persistente	http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCAM
3	Insecure HTTP Endpoint	MEDIUM	6.0	Persistente	http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCAM
4	Sensitive Data in Logs	MEDIUM	6.0	Persistente	https://superapp-api-test.miniprogramas.claro.com.co
5	Falta cabecera Strict-Transport-Security (HSTS)	MEDIUM	6.0	Persistente	https://superapp-api-test.miniprogramas.claro.com.co
6	Divulgación de software (cabecera Server)	LOW	3.0	Persistente	https://superapp-api-test.miniprogramas.claro.com.co

Detalle tecnico

1. Hardcoded Credentials (CRITICAL)

Estado: Persistente | CWE: CWE-798
Endpoint: <https://superapp-api-test.miniprogramas.claro.com.co>
Descripcion: Coincidencia de patrón HARDCODED_CREDENTIALS en main/ui/pages/pseForm/pseForm.js:222.
Recomendacion: No almacenes contraseñas en código; usa gestores de secretos.

2. Insecure HTTP Endpoint (MEDIUM)

Estado: Persistente | CWE: CWE-319
Endpoint: <http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCAMR01?wsdl>
Descripcion: Coincidencia de patrón INSECURE_HTTP en test/getStatusViewModel.test.js:15.
Recomendacion: Usa https:// para APIs en producción y fuerza redirección HTTP→HTTPS.

3. Insecure HTTP Endpoint (MEDIUM)

Estado: Persistente | CWE: CWE-319
Endpoint: <http://192.168.5.25:10021/web/services/CLCAMR01Service/CLCAMR01?wsdl>
Descripcion: Coincidencia de patrón INSECURE_HTTP en test/validCardViewModel.test.js:16.
Recomendacion: Usa https:// para APIs en producción y fuerza redirección HTTP→HTTPS.

4. Sensitive Data in Logs (MEDIUM)

Estado: Persistente | CWE: CWE-532
Endpoint: <https://superapp-api-test.miniprogramas.claro.com.co>
Descripcion: Coincidencia de patrón SENSITIVE_DATA_LOGGING en main/ui/pages/rechargeAmount/rechargeAmount.js:194.
Recomendacion: No registres contraseñas ni tokens; usa enmascaramiento o niveles de log seguros.

5. Falta cabecera Strict-Transport-Security (HSTS) (MEDIUM)

Estado: Persistente | CWE: CWE-319

Endpoint: <https://superapp-api-test.miniprogramas.claro.com.co>

Descripcion: No se detectó HSTS en la respuesta; los clientes no reciben la política de forzar HTTPS.

Recomendacion: Añade HSTS con un max-age adecuado (y preload si aplica) en el balanceador o API gateway.

6. Divulgación de software (cabecera Server) (LOW)

Estado: Persistente | CWE: CWE-200

Endpoint: <https://superapp-api-test.miniprogramas.claro.com.co>

Descripcion: El servidor anuncia: 'CloudFront'

Recomendacion: Oculta o reduce la cabecera Server y X-Powered-By en producción.